Alumno:

Samuel Jonathan Trujillo Bolaños

Docente:

José Miguel Carrera Pacheco

8°B

Proyecto: Conecta-Tehuacán

INVESTIGACION:

S - 13. Protección de rutas y recursos por rol

1. Objetivo

Verificar que el sistema cumpla con los criterios solicitados para:

- Protección de rutas por rol.
- Bloqueo de accesos indebidos.
- Validación de seguridad mediante pruebas.

2. Alcance de la revisión

La revisión se realizó sobre el backend, principalmente en las rutas de vacantes y en los middlewares encargados de autenticar, autorizar y filtrar entradas peligrosas.

Componentes revisados:

- Rutas protegidas de vacantes.
- Validación de token y autenticación.
- Restricción por rol y permisos.
- Restricción por ownership.
- Protección contra entradas maliciosas.
- Suite de pruebas agregada para validación.

Evidencia principal:

- jobs.routes.js
- auth.middleware.js
- authorization.middleware.js
- securityProtection.middleware.js
- jobs-access.test.js
- jobs-service.test.js

3. Metodología QA aplicada

Se realizó una revisión funcional y técnica enfocada en los escenarios críticos de acceso y seguridad.
Se validó la lógica implementada y se preparó una suite de pruebas automatizadas para cubrir los casos principales.
También se revisó la coherencia entre la política de acceso definida por roles y el comportamiento real del servicio.

4. Escenarios evaluados

Autenticación:

- Acceso a rutas protegidas sin token.
- Acceso con token mal formado.
- Acceso con esquema incorrecto en encabezado Authorization.

Autorización por rol:

- Usuario con rol aspirante intentando crear vacantes.
- Usuario con rol reclutador creando vacantes.
- Usuario con rol admin accediendo a operaciones protegidas.

Control de acceso indebido:

- Intento de modificar recursos sin autenticación.
- Intento de editar vacantes ajenas.
- Intento de cambiar estado de vacantes sin ownership.

Seguridad de entrada:

- Envío de payload con XSS.
- Manipulación de ruta tipo path traversal.
- Envío de caracteres nulos en parámetros.

5. Hallazgos y validación

Protección por rol:

- El sistema sí restringe rutas según el rol del usuario.
- aspirante no puede acceder a operaciones de creación o modificación de vacantes.
- reclutador y admin sí pueden acceder a las rutas autorizadas.

Bloqueo de accesos indebidos:

- Se bloquea correctamente el acceso cuando no existe token.
- Se bloquea el acceso cuando el token es inválido o malformado.
- Se bloquean intentos de modificación no autorizada sobre recursos ajenos.

Validaciones de seguridad:

- El middleware de protección detecta patrones sospechosos en la entrada.
- Se contemplan bloqueos para XSS, path traversal y caracteres no permitidos.
- La cobertura preparada responde al objetivo de validar accesos indebidos y seguridad básica en backend.

Ajuste QA detectado y corregido:

- Se identificó una inconsistencia: el rol admin superaba la autorización por middleware, pero podía ser bloqueado después por la validación de ownership.
- Ese comportamiento fue corregido para alinear la lógica con la política esperada del sistema.
- Evidencia del ajuste:
    - jobs.controller.js (line 59)
    - jobs.service.js (line 150)

6. Resultado por criterio solicitado

Rutas protegidas por rol
Estado: **Cumple**
Observación: la lógica distingue correctamente entre usuarios sin permisos, reclutadores y administradores.

Evidencia de bloqueo de accesos indebidos
Estado: **Cumple**
Observación: se cubrieron escenarios de acceso sin token, token inválido y modificación de recursos ajenos.

Tests de seguridad
Estado: **Cumple en cobertura preparada**
Observación: se generaron pruebas para entradas maliciosas y manipulación de rutas.

7. Estado de la evidencia

La evidencia técnica quedó integrada en el proyecto mediante la suite de pruebas y los ajustes en backend.
También se agregó el comando de ejecución:

- package.json (line 5)

Estado de ejecución en esta sesión:

- No fue posible correr Node desde la terminal disponible.
- Por esa razón, la ejecución final no quedó certificada en runtime dentro de esta sesión.

8. Conclusión QA

Desde el punto de vista de QA funcional y técnico, el sistema sí cumple con lo solicitado porque:

- Protege rutas por rol.
- Bloquea accesos indebidos.
- Cuenta con pruebas de seguridad para los escenarios principales.

9. Dictamen final

Dictamen QA: Cumple

Condición: pendiente únicamente la evidencia de ejecución local de la suite para cierre formal de validación.